Laboratorio de ARP Spoofing

Ataque, detección y mitigación de un ataque Man-in-the-Middle en una red local

Autor	Raul Velasquez (@rauljvc8)
Perfil	Cybersecurity Consultant — South Florida
GitHub	github.com/rauljvc8
Fecha	Octubre 2026
Clasificación	Material educativo — entorno de laboratorio aislado

1. Resumen ejecutivo

Este informe documenta un laboratorio práctico de **ARP Spoofing** (envenenamiento de la caché ARP) ejecutado en un entorno virtual completamente aislado. Se demuestra, de principio a fin, cómo un atacante situado en la misma red local puede interponerse entre dos equipos (ataque **Man-in-the-Middle**), interceptar su tráfico y capturar credenciales que viajan sin cifrar. El laboratorio incluye además el análisis defensivo: cómo **detectar** y cómo **mitigar** el ataque. El objetivo es formativo y de portafolio profesional.

2. Alcance y aviso ético

Todas las pruebas se realizaron sobre máquinas virtuales propias, en una red **Host-Only** totalmente aislada, sin acceso a internet ni a ninguna red de terceros. El ARP Spoofing contra equipos o redes sin autorización es **ilegal**. Este material es exclusivamente educativo y busca comprender el ataque para poder defenderse de él.

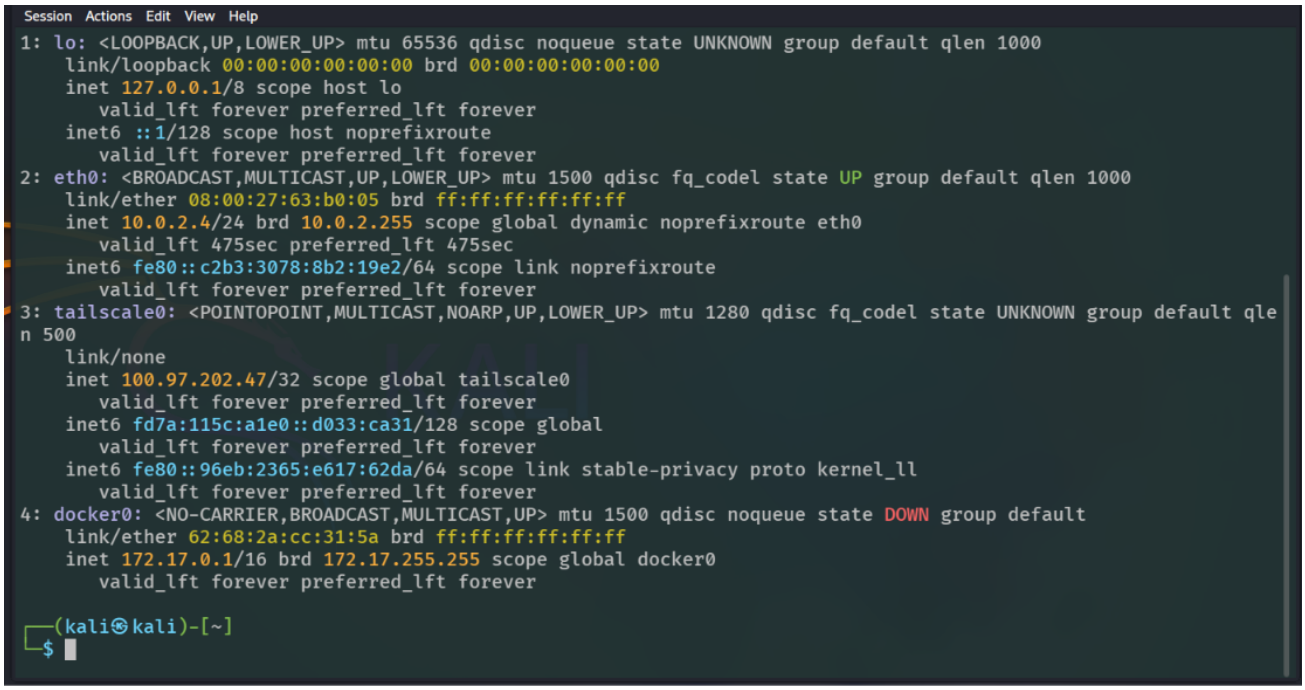
3. Entorno del laboratorio

Rol	Sistema	IP	MAC
Atacante	Kali Linux	192.168.56.102	08:00:27:63:B0:05
Víctima	Debian Linux	192.168.56.103	08:00:27:D1:65:C7
"Gateway" del lab	Windows (host)	192.168.56.101	0A:00:27:00:00:0E

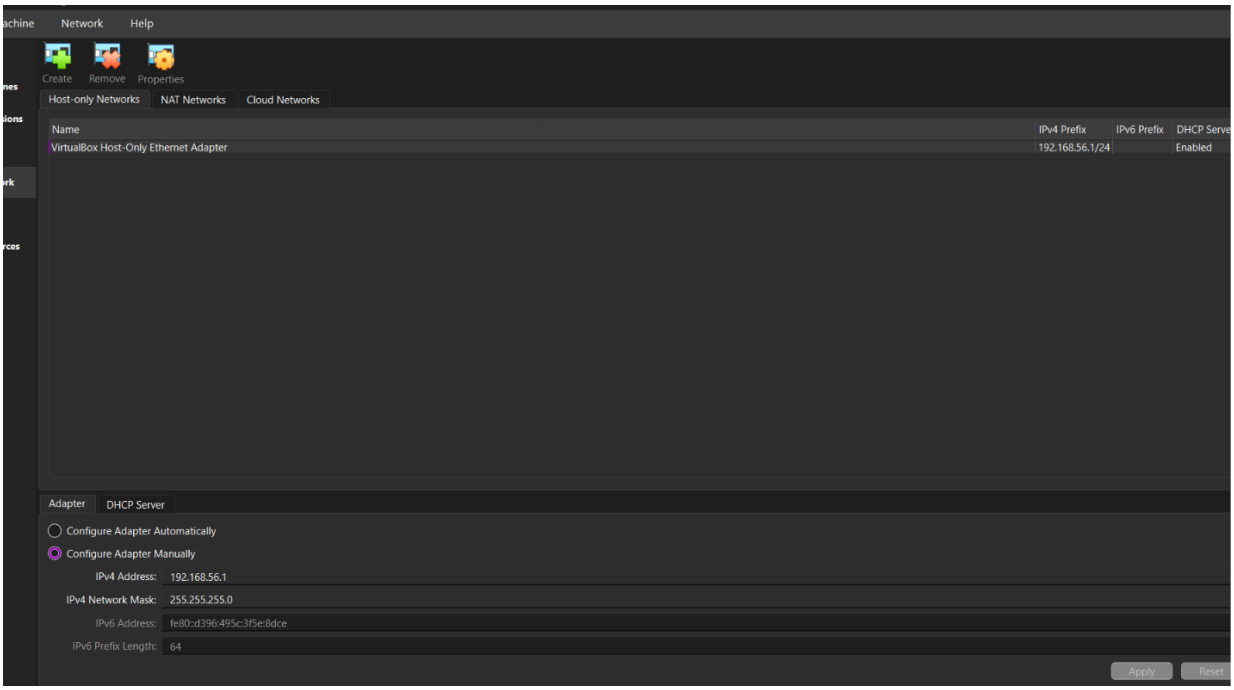
Herramientas: VirtualBox (red Host-Only), Kali Linux, **arpspoof** (paquete dsniff), **nmap**, **Wireshark** y, opcionalmente, ettercap.

4. Fase 1 — Montaje de la red aislada

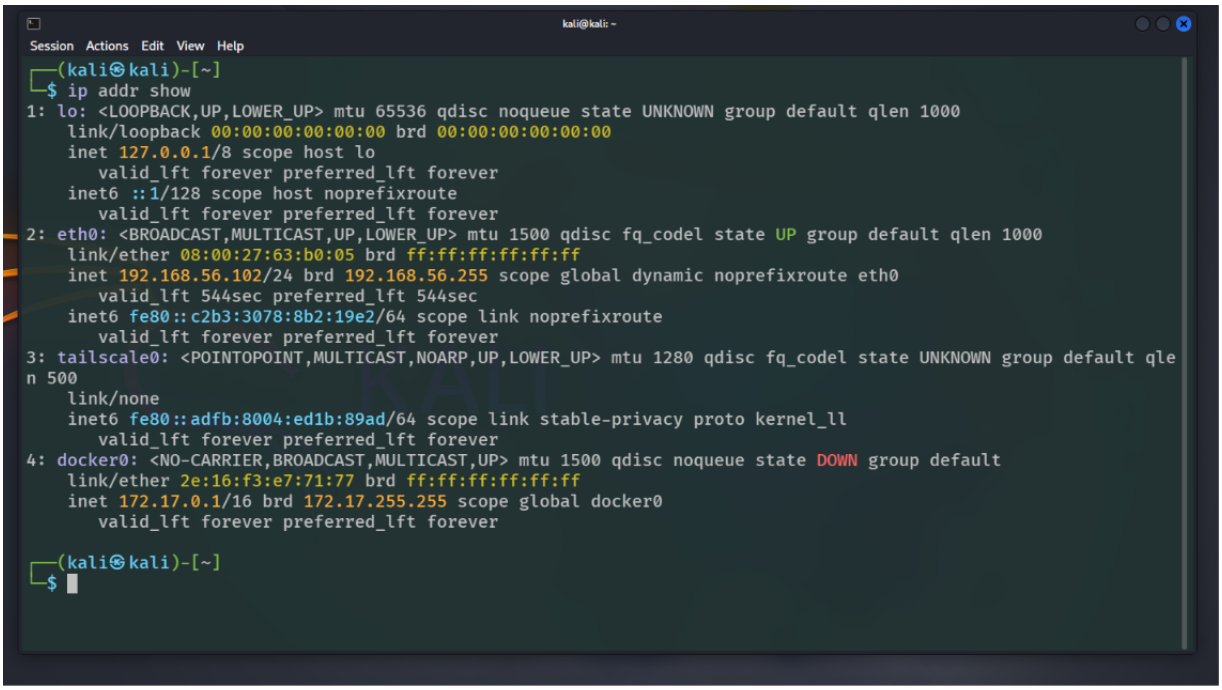
Las VMs se configuraron en modo **Host-Only** (segmento 192.168.56.0/24). El modo NAT **no** permite ARP Spoofing porque aísla las VMs en la capa 3; Host-Only crea un segmento de capa 2 real, requisito del ataque.



Captura 01. *Estado inicial en modo NAT (10.0.2.x): el ataque no funcionaría aquí.*



Captura 03. *Red Host-Only creada en VirtualBox: segmento 192.168.56.0/24 con DHCP.*



Captura 05. *Kali ya en la red Host-Only aislada: eth0 = 192.168.56.102/24.*

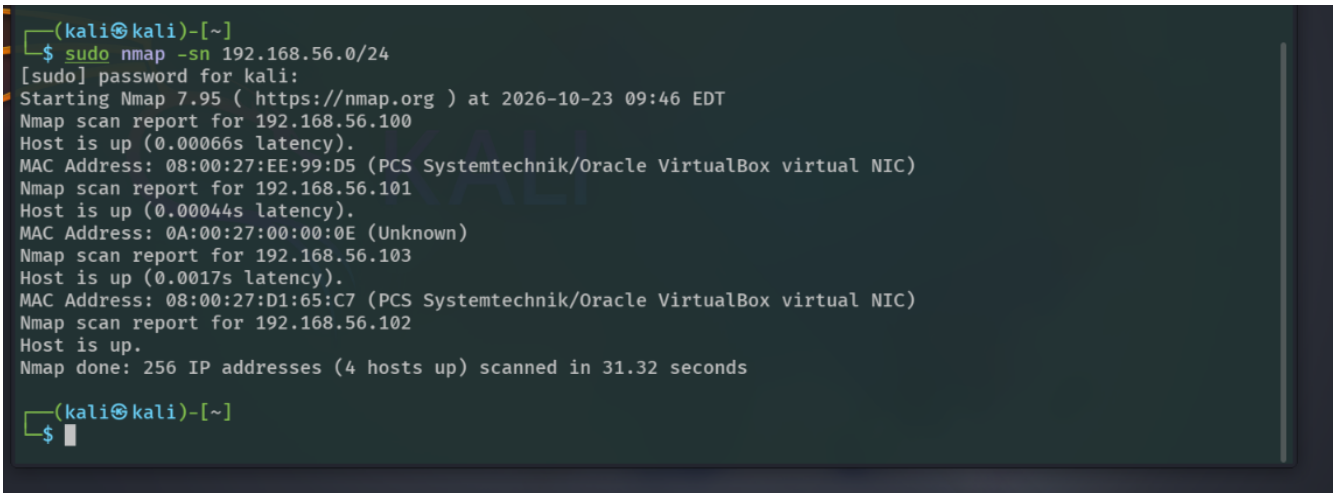
5. Fase 2 — Por qué ARP es vulnerable

El protocolo **ARP** (Address Resolution Protocol) traduce direcciones IP (capa 3) en direcciones MAC (capa 2) dentro de una red local. Cuando un equipo necesita enviar datos a una IP de su red, pregunta en broadcast «¿quién tiene esta IP?» y confía en la respuesta que recibe. El problema de diseño: ARP **no tiene autenticación**. Cualquier equipo puede responder, incluso mintiendo. El atacante aprovecha esto enviando respuestas ARP falsas para asociar la IP del gateway con su propia MAC, de modo que la víctima le envíe todo su tráfico.

6. Fase 3 — Reconocimiento

Descubrimiento de hosts vivos en la red del laboratorio:

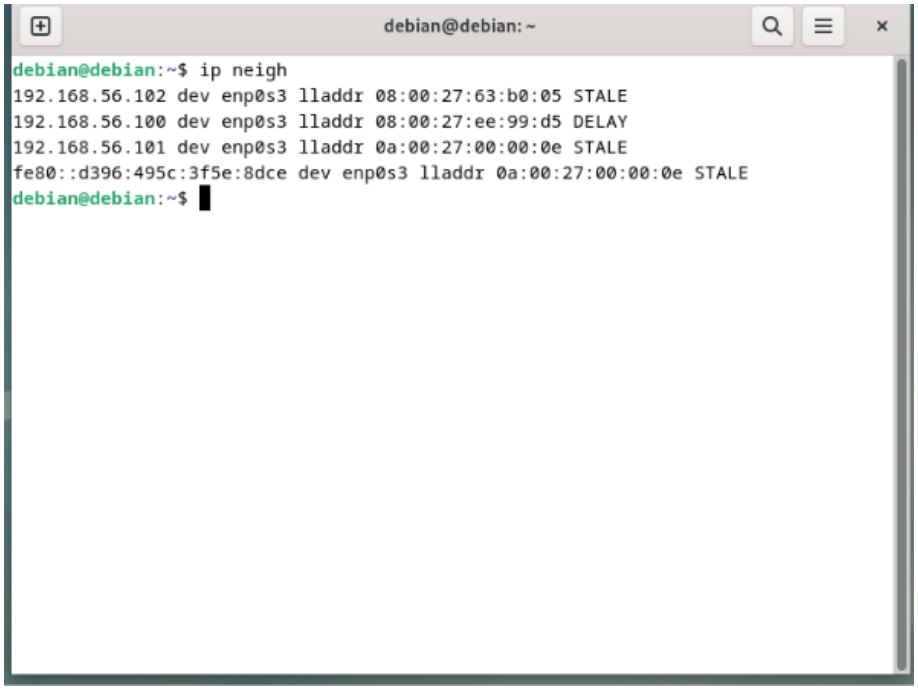
```
sudo nmap -sn 192.168.56.0/24
```



Captura 06. *nmap identifica la víctima (.103), el host (.101) y Kali (.102).*

Foto del «antes» de la caché ARP de la víctima. Esta es la evidencia base: la IP del host (.101) apunta a su MAC **real**.

```
ip neigh
192.168.56.101 ... lladdr 0a:00:27:00:00:0e   <-- MAC real del host
192.168.56.102 ... lladdr 08:00:27:63:b0:05   <-- MAC real de Kali
```



Captura 08. *Caché ARP de la víctima ANTES del ataque (MAC reales).*

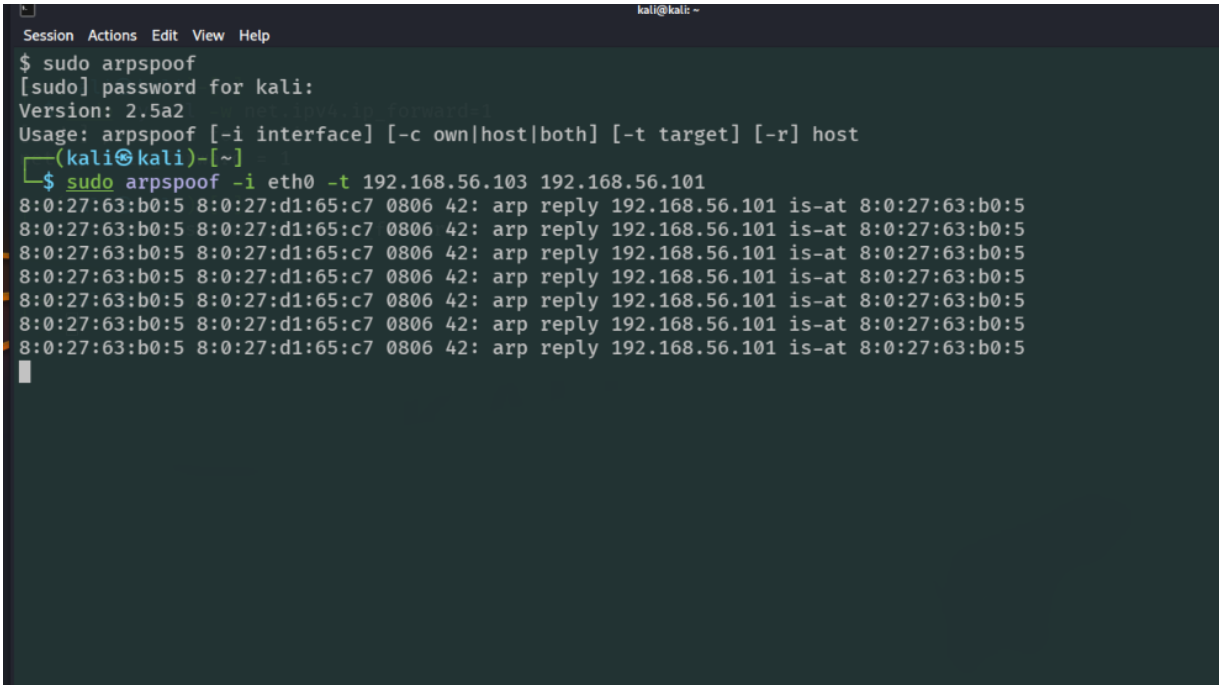
7. Fase 4 — Ejecución del ataque

El reenvío de paquetes (IP forwarding) se habilita primero para que el MITM sea **sigiloso**: la víctima no pierde conexión y no sospecha.

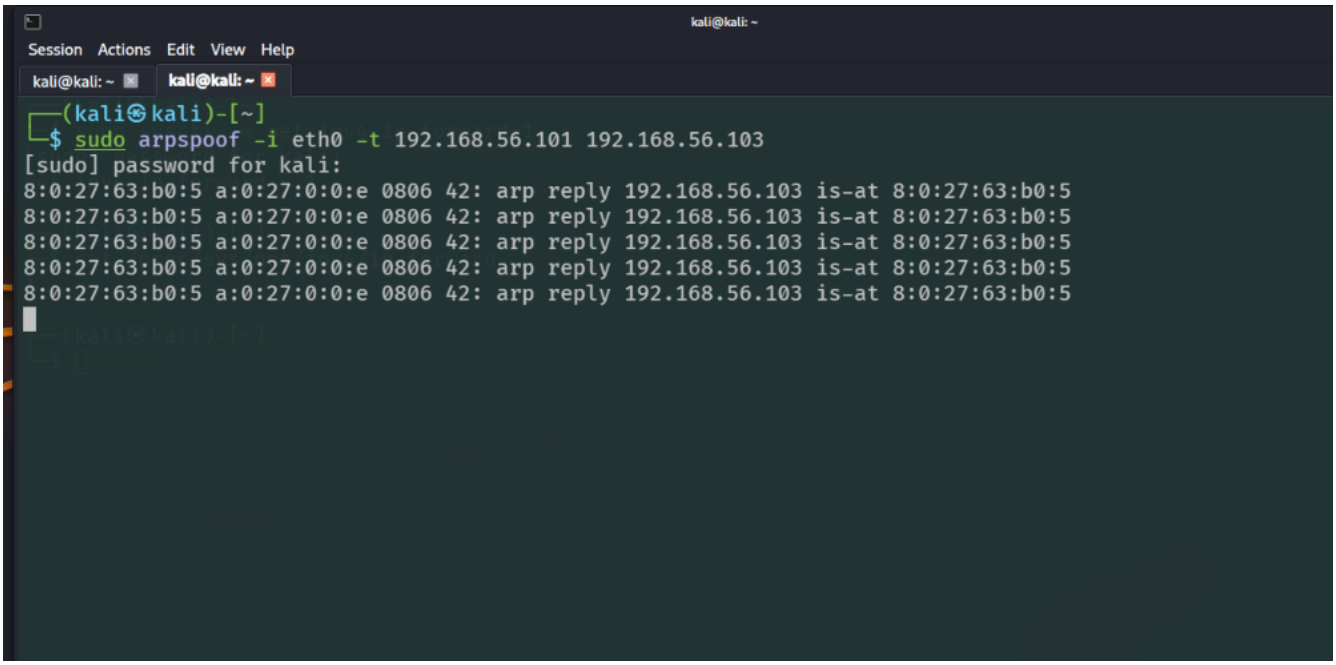
```
# En Kali
sudo sysctl -w net.ipv4.ip_forward=1

# Terminal 1 - enganar a la victima: el .101 soy yo
sudo arpspoof -i eth0 -t 192.168.56.103 192.168.56.101

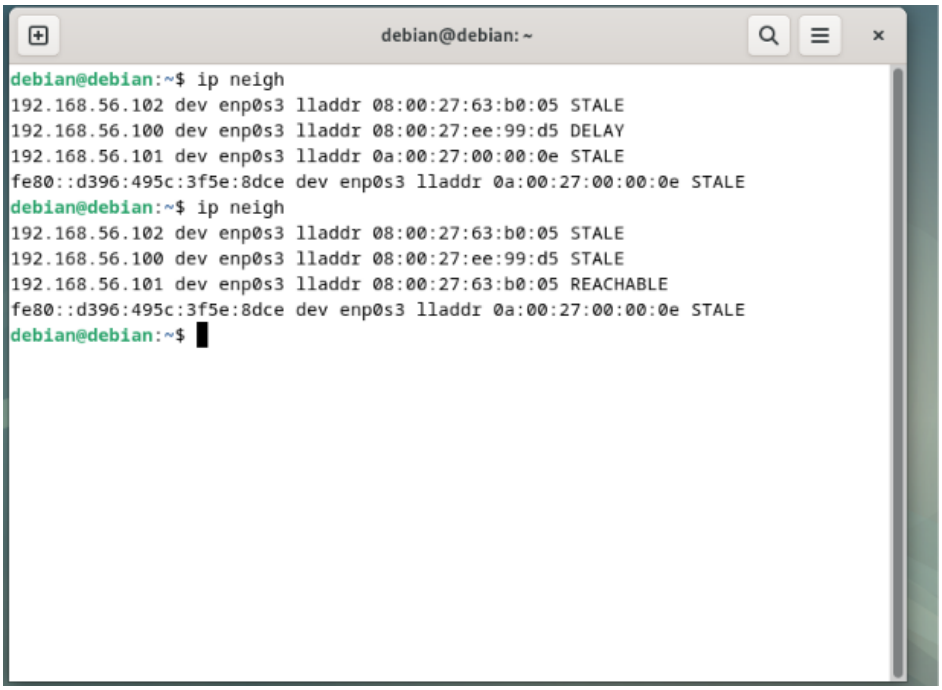
# Terminal 2 - enganar al host: la victima .103 soy yo
sudo arpspoof -i eth0 -t 192.168.56.101 192.168.56.103
```



Captura 10. *arpspoof (Terminal 1): respuestas ARP falsas enviadas a la víctima.*



Captura 11. *arpspoof (Terminal 2): se engaña también al host (envenenamiento bidireccional).*



Captura 12. *PRUEBA DEL ATAQUE: la caché ARP de la víctima cambia .101 a la MAC de Kali.*

La entrada de la víctima para .101 cambió de **0a:00:27:00:00:0e** (host real) a **08:00:27:63:b0:05** (Kali), con estado REACHABLE: la víctima está usando activamente la entrada envenenada.

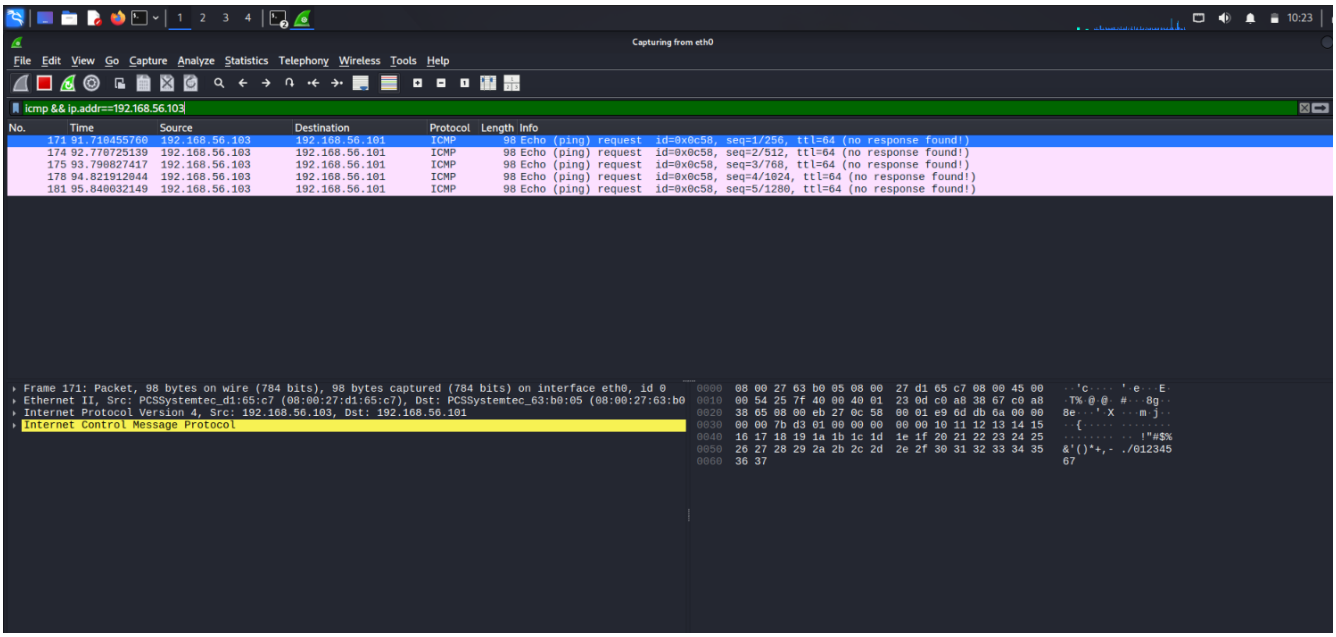
8. Fase 5 — Demostración del MITM

Para que el reenvío sea completo (y no se convierta en un corte de servicio que delataría al atacante) se ajustan varios parámetros del kernel:

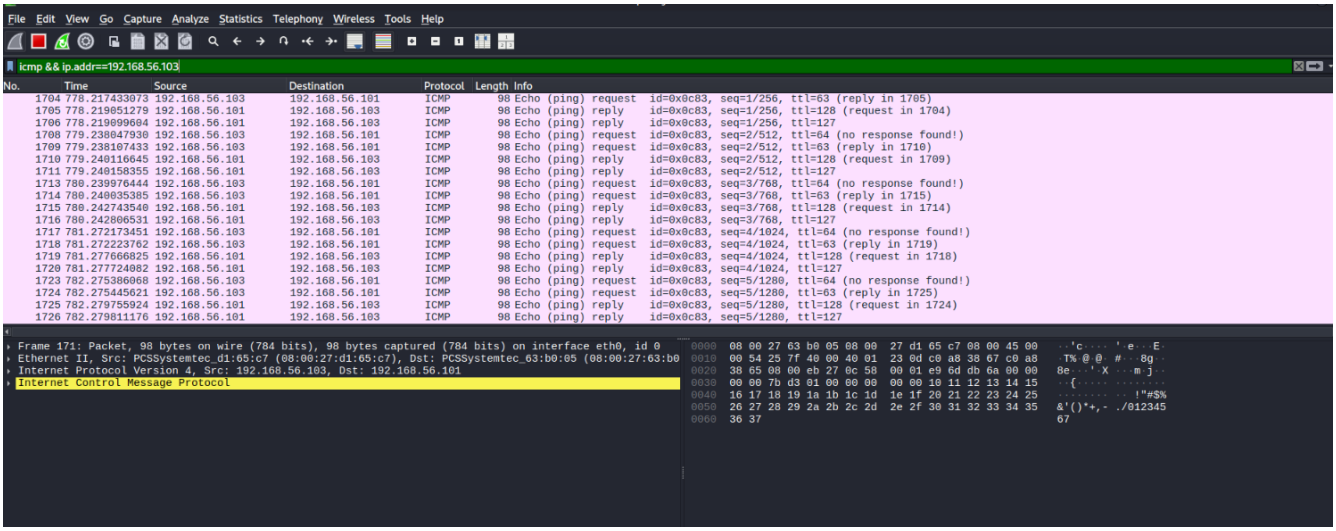
```
sudo sysctl -w net.ipv4.conf.all.rp_filter=0
sudo sysctl -w net.ipv4.conf.eth0.rp_filter=0
sudo sysctl -w net.ipv4.conf.all.send_redirects=0
sudo sysctl -w net.ipv4.conf.eth0.send_redirects=0
sudo iptables -P FORWARD ACCEPT
```

8.1 Prueba forense: el TTL

En Wireshark cada paquete aparece **duplicado** con el TTL decrementado en 1 (64→63 en las peticiones, 128→127 en las respuestas). Ese decremento es la huella inequívoca de un equipo intermediario reenviando el tráfico: la prueba técnica del MITM.



Captura 13. *Wireshark: el tráfico ICMP de la víctima hacia el host aparece en Kali (intercepción).*



Captura 17. *Wireshark: cada paquete aparece dos veces con el TTL restado en 1 (reenvío por Kali).*

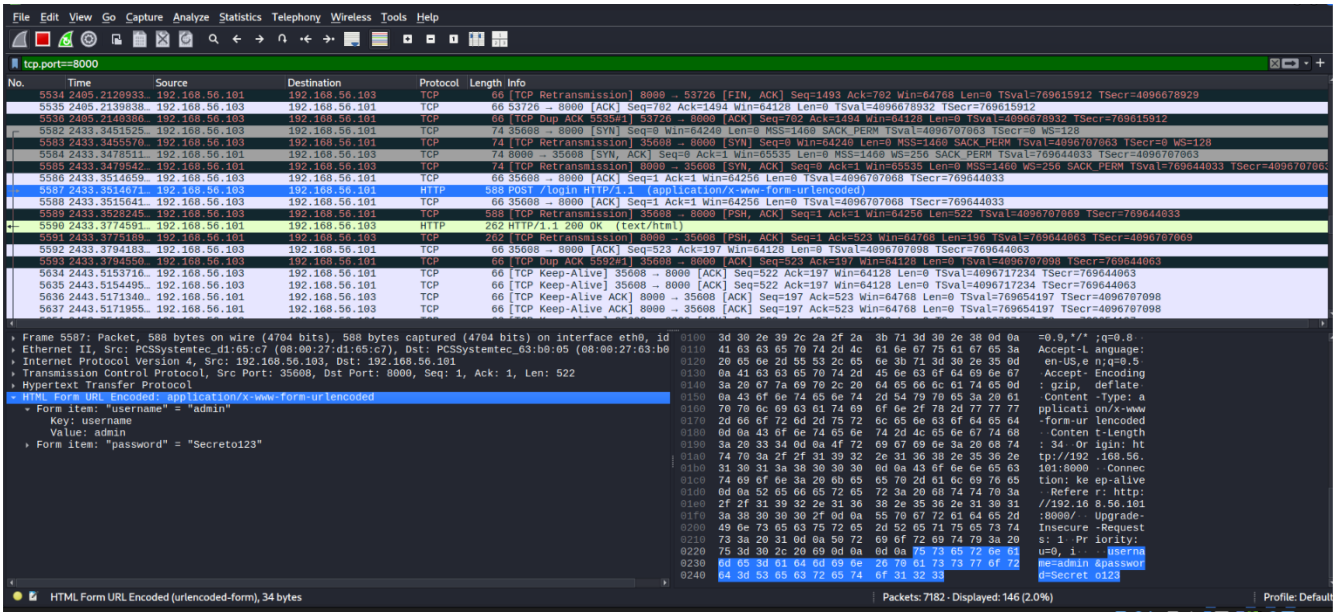
8.2 Captura de credenciales en texto plano

La víctima accede a un portal de login por **HTTP sin cifrar** y envía usuario y contraseña. Como el servicio corre en el puerto 8000, en Wireshark se usa el filtro `tcp.port == 8000` y la opción *Follow* → *HTTP Stream*. Las credenciales aparecen en claro:

```
username=admin&password=Secreto123
```



Captura 18. *Portal de login HTTP sin cifrar, tal como lo ve la víctima.*



Captura 19. *CAPTURA ESTRELLA: usuario y contraseña de la víctima interceptados en texto plano.*

Lección central: si el portal hubiera usado HTTPS/TLS, el tráfico habría viajado cifrado y el atacante, aun interceptándolo, no habría podido leer las credenciales.

9. Fase 6 — Detección (perspectiva Blue Team / SOC)

Señal	Cómo detectarla
Entradas ARP duplicadas	Dos IP con la misma MAC, o una IP cuya MAC cambia de golpe.
ARP replies anómalos	Muchas respuestas ARP no solicitadas (Wireshark: arp).
Cambio de TTL	La víctima ve su TTL bajar 1 (un salto extra en la ruta).
Herramientas	arpwatch, XArp, reglas de IDS/IPS (Suricata, Snort).
Monitoreo SOC	Vigilar la tabla ARP de activos críticos; alertar por cambios MAC-IP.

10. Fase 7 — Mitigación

Control	Descripción
ARP estático	Fijar la MAC real del gateway en equipos críticos.
Dynamic ARP Inspection	El switch valida ARP contra DHCP snooping (defensa empresarial).
Port Security	Limitar las MAC permitidas por puerto del switch.
Cifrado extremo a extremo	HTTPS/TLS, SSH, VPN: la intercepción pierde valor.
Segmentación (VLANs)	Reducir el dominio de broadcast y la superficie de ataque.

Ejemplo de entrada ARP estática en Linux:

```
sudo ip neigh add 192.168.56.101 lladdr 0a:00:27:00:00:0e \
        dev enp0s3 nud permanent
```

11. Conclusiones

El laboratorio demostró que el ARP Spoofing sigue siendo un ataque viable y de bajo costo en redes locales mal protegidas, y que su impacto es grave: intercepción total del tráfico y robo de credenciales en claro. La defensa combina controles técnicos (DAI, ARP estático, port security) y, sobre todo, el **cifrado del tráfico**, que neutraliza el valor de la intercepción. Este ejercicio refuerza competencias tanto ofensivas (red team) como defensivas (blue team / SOC / GRC).